PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Guide de l'homologation de sécurité des SI

03-810 ANSSI et DINUM - Le guide de l'homologation de sécurité des systèmes d'information (2025) — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'homologation est une décision formelle par laquelle une autorité accepte les risques liés à l'emploi d'un système d'information.
2. La gouvernance repose sur trois lignes de maîtrise incluant la DSI en première ligne, le RSSI en deuxième et le comité d'homologation en troisième.
3. La démarche suit tout le cycle de vie du SI, de sa conception jusqu'à son décommissionnement.

La nouvelle doctrine

Notion	À retenir
Auteurs et esprit	Écrit par **ANSSI** et **DINUM**. Processus dynamique de **pilotage par le risque**, pragmatique, réduisant les coûts humains et financiers.
Les changements	Acceptation des **risques métier** par une autorité. **Trois niveaux progressifs** selon criticité/exposition. Disparition des homologations provisoires/test. Démarche simplifiée pour SI peu critiques/exposés.

L'homologation de sécurité

Notion	À retenir
Le principe	Préalable à toute utilisation d'un **SI**. Un SI exploité sans homologation doit être **arrêté** ou homologué dans un **délai raisonnable**. Permet d'identifier/traiter les risques, appliquer la réglementation, valider le plan d'action et **engager l'autorité**.
Contexte et direction	Comprendre le contexte (**PESTEL**, **SWOT**) pour évaluer l'**appétence au risque** ; la direction fixe les politiques, fournit ressources et budgets, sensibilise.
Durée	**3 ans** au plus (SI réglementés, Secret), **2 ans** pour le **Très Secret** ; revue de sécurité **au moins annuelle** présidée par l'autorité ; pas de renouvellement sans actions menées.

Synthèse de la sécurisation du SI

Notion	À retenir
Les trois lignes	1ère : **DSI** (opérationnelle), 2ème : **RSSI** (support/expertise), 3ème : **comité d'homologation** (contrôle/avis).
Périmètre/Écosystème	Supports, applications, équipements, utilisateurs, lieux. Homologations distinctes si **niveaux de protection différents**. Garanties via **homologation**, **certification** ou **contrat**.
Réglementations	Soumis à **PSSIE**, **RGS**, **décret n° 2022-513**, **IGI 1300**, **IGI 2102**, **II 2100**, **SIIV**. La **réglementation prime** sur la politique.
Mesures et plans	Mesures **proportionnées aux risques**. Cartographie (**métier**, **applicative**, **infrastructure**) sauvegardée **hors du SI**. Plan de résilience (**MTPD**, **RTO**, **PCA**/**PRA**).
Risques et audits	Risque = **événement redouté** + **scénario de menace** (gravité, vraisemblance). Traitement : **acceptation**, **réduction**, **transfert** ou **refus**. Plan d'action **SMART** (propriétaire, date). **EBIOS RM** obligatoire si l'ANSSI est AH.

Les 4 étapes de l'homologation

Notion	À retenir
Comité d'homologation	Présidé par le **RSSI** ou le **CSN** ; réunit responsables métiers, **MOA**, **MOE**, **DSI**, auditeurs, experts et gestionnaire des risques (**impartiaux**).
Niveau de démarche	Croisement **criticité** (mineure à critique) et **exposition** (nulle à totale) → niveau **simplifié**, **intermédiaire** ou **renforcé**.
Évaluation et avis	Le comité **évalue** et propose un **avis justifié** ; **avis sous réserve** possible (réserves levées en **12 mois** max). Simplifié/intermédiaire : **autodéclaration** de la première ligne, avis du RSSI, contrôle par échantillonnage ; renforcé : **commission**.
Organisation commission	Autorité : **AQSSI**, **AH déléguée** ou **dirigeant habilité** ; décision **écrite** sans renouvellement automatique ; **SI en test** (sans données réelles/déconnecté) non soumis.

Fin de l'homologation

> L'homologation prend fin au **décommissionnement** : données **détruites, transférées ou conservées**, composants **démantelés**.

Déclinaison du ministère de la Justice

Notion	À retenir
Cadre	Guide v2 (2024-2025) : homologation de **tous** les SI selon la politique ministérielle de sécurité numérique ; niveaux **élémentaire**, **standard**, **renforcé** ; dérogation du **FSSI** si un référentiel n'est pas pris en compte.
Lancement	Réunion de lancement (contributeurs, **RACI**) → **note d'orientation**, premier livrable porté par le **CSN**.

Les chaînes d'acteurs

Chaîne	Acteurs
Décisionnelle	l'**AH**
Fonctionnelle	le **CSN** et le **chef de projet** ou **rapporteur**
Opérationnelle	les **RSSI** de la **MOA** et de la **MOE**
Support	le **FSSI** et la **déléguée ministérielle à la protection des données**

Pièges et confusions

- ⚠ Confondre le comité d'homologation, qui propose l'avis, avec la commission, où l'autorité décide.
- ⚠ Croire qu'il existe encore des homologations provisoires ou de test.
- ⚠ Oublier que l'avis sous réserve impose de lever les réserves en 12 mois au maximum.
- ⚠ Penser que le renouvellement de l'homologation est automatique.
- ⚠ Confondre la première ligne (DSI) avec la deuxième ligne (RSSI) ou la troisième (comité d'homologation).

Sigles et définitions

Autorité d'homologation (AH)	Autorité qui prononce la décision d'homologation.
AQSSI	Autorité qualifiée de la sécurité des systèmes d'information, juridiquement responsable.
MCO	Maintien en condition opérationnelle par la maintenance préventive, corrective et la gestion de l'obsolescence.
MCS	Maintien en condition de sécurité par la surveillance, la reconnaissance et l'application des correctifs.
RTO	Objectif de délai de remise en route.
MTPD	Durée maximale d'interruption tolérable.
EBIOS Risk Manager	Méthode d'analyse de risque de l'ANSSI et du Club EBIOS.

Auto-test

1. Quelle est la durée maximale recommandée pour une homologation ?
2. Quels sont les trois niveaux de démarche d'homologation ?
3. Quelle méthode d'analyse de risque est obligatoire quand l'ANSSI est autorité d'homologation ?
4. À quelle fréquence la revue de sécurité de tous les SI doit-elle être effectuée ?
5. Que doit-on faire d'un SI en test pour qu'il ne soit pas soumis à l'homologation ?

Réponses : **1.** 3 ans (et 2 ans pour le Très Secret). · **2.** Simplifié, intermédiaire et renforcé. · **3.** EBIOS Risk Manager. · **4.** Au moins annuelle. · **5.** Il doit être sans données réelles ou déconnecté.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.